

25. Determine whether management effectively provides secure customer access to financial services and plans for potential interruptions in service. Review whether management does the following:
 - a. Develops and maintains policies and procedures to securely offer and ensure the resilience of remote financial services (e.g., using appropriate authentication, layered security controls, and fraud detection monitoring). (For additional questions, refer to the “Mobile Financial Services” examination procedures.)⁶⁵
 - b. Plans and coordinates with ISPs and third parties to minimize exposure to incidents and continue services when faced with an incident (e.g., monitors threat alerts, service availability, applications, and network traffic for indicators of nefarious activity, and ensures traffic filtering).
 - c. Develops and tests a response plan in conjunction with the institution’s ISPs and third-party service providers to mitigate the interruption of mobile or remote financial services.
26. Determine whether management develops customer awareness and education efforts that address both retail (consumer) and commercial account holders.
27. Determine whether management uses applications that were developed by following secure development practices and that meet a prudent level of security. Determine whether management develops security control requirements for applications, whether they are developed in-house or externally. Determine whether information security personnel are involved in monitoring the application development process to verify secure development practices. Review whether applications in use provide the following capabilities:
 - a. Provide a prudent level of security (e.g., password and audit policies), audit trails of security and access changes, and user activity logs.
 - b. Have user and group profiles to manage user access for applications if they are not part of a centralized identity access management system.
 - c. Provide the ability to change and disable default application accounts upon installation.
 - d. Allow administrators to review and install patches for applications in a timely manner.
 - e. Use validation controls for data entry and data processing.
 - f. Integrate additional authentication and encryption controls, as necessary.
 - g. Protect web or Internet-facing applications through additional controls, including web application firewalls, regular scanning for new or recurring vulnerabilities, mitigation or remediation of common security weaknesses, and network segregation.
28. With respect to developed software, determine whether institution management does the following:
 - a. Reviews mitigation of potential flaws in applications.
 - b. Obtains attestation or evidence from third-party developers that the applications acquired by the institution meet the necessary security requirements and that noted vulnerabilities or flaws are remediated in a timely manner.

⁶⁵ Refer to [appendix E](#) of the *IT Handbook*’s “Retail Payment Systems” booklet.

- c. Performs ongoing risk assessments to consider the adequacy of application-level controls in light of changing threat, network, and host environments.
 - d. Implements minimum controls recommended by third-party service providers and considers supplemental controls as appropriate.
 - e. Reviews available audit reports, and considers and implements appropriate control recommendations.
 - f. Collects data to build metrics and reporting of configuration management compliance, and vulnerability management.
29. For database security, determine whether management implemented or enabled controls commensurate with the sensitivity of the data stored in or accessed by the database(s). Determine whether management appropriately restricts access and applies the rule of least privilege in assigning authorizations.
30. Determine how and where management uses encryption and if the type and strength are sufficient to protect information appropriately. Additionally, determine whether management has effective controls over encryption key management.
31. Determine whether management appropriately oversees the effectiveness of information security controls over outsourced operations and is accountable for the mitigation of risks involved with the use of third-party service providers. Review the due diligence involved, security controls to mitigate risk, and monitoring capabilities over the institution's third parties. Review the institution's policies, standards, and procedures related to the use of the following:
- a. Third-party service providers that facilitate operational activities (e.g., core processing, mobile financial services, cloud storage and computing, and managed security services).
 - b. Due diligence in research and selection of third-party service providers.
 - c. Contractual assurances from third-party service providers for security responsibilities, controls, and reporting.
 - d. Nondisclosure agreements with third-party service providers with access to the institution's systems and data (including before, during, and following termination of the contract).
 - e. Independent review of the third-party service provider's security through appropriate reports from audits and tests.
 - f. Coordination of incident response policies and contractual notification requirements.
 - g. Verification that information and cybersecurity risks are appropriately identified, measured, mitigated, monitored, and reported.
32. If the institution outsources cloud computing or storage to a third-party service provider, refer to the FFIEC's "Outsourced Cloud Computing" statement.⁶⁶

⁶⁶ See the FFIEC's "[Outsourced Cloud Computing](#)" statement.

33. If the institution outsources the management of security services to a third-party service provider, refer to the information available in appendix D of the *IT Handbook's* "Outsourcing Technology Services" booklet and the related examination procedures.⁶⁷
34. Determine whether management effectively manages the following information security considerations related to business continuity planning. Review management's ability to do the following:
 - a. Identify personnel with key information security roles during a disaster and training of personnel in those roles.
 - b. Define information security needs for backup sites and alternate communication networks.
 - c. Develop policies that address the concepts of information security incident response and resilience and test information security incident scenarios.
35. Determine whether management has an effective log management process that involves a central logging repository, timely transmission of log files, and effective log analysis. Review whether management has the following:
 - a. Log retention policies that meet incident response and analysis needs.
 - b. Processes for the security and integrity of log files (e.g., encryption of log files, adequate storage capacity, secure backup and disposal of logs, logging to a separate computer, use of read-only media, controlled log parameters, and restricted access to log files).
 - c. Independent review of logging practices.
 - d. Processes to effectively collect, aggregate, analyze, and correlate security event information from discrete systems and applications.

Objective 7: Determine whether management has effective risk monitoring and reporting processes.

1. Determine whether the institution has risk monitoring and reporting processes that address changing threat conditions in both the institution and the greater financial industry. Determine whether these processes address information security events faced by the institution, the effectiveness of management's response, and the institution's resilience to those events. Review whether the reporting process includes a method of disseminating those reports to appropriate members of management.
2. Determine whether the risk monitoring and reporting process is regular and prompts action, when necessary, in a timely manner.
3. Determine whether program monitoring and reporting instigate appropriate changes that are effective in maintaining an acceptable level of risk.

⁶⁷ Refer to the *IT Handbook's* "Outsourcing Technology Services" booklet for the [MSSP Examination Procedures](#).

4. Determine whether management develops and effectively uses metrics as part of the risk monitoring and reporting processes for the information security program. Review whether management does the following:
 - a. Uses metrics that are timely, comprehensive, and actionable to improve the program's effectiveness and efficiency.
 - b. Develops metrics that demonstrate the extent to which the information security program is implemented and whether the program is effective.
 - c. Uses metrics to measure security policy implementation, the adequacy of security services delivery, and the impact of security events on business processes.
 - d. Establishes metrics to measure conformance to the standards and procedures that are used to implement policies.
 - e. Uses metrics to quantify and report risks in the information security program.

Objective 8: *Determine whether management has security operations that encompass necessary security-related functions, are guided by defined processes, are integrated with lines of business and activities outsourced to third-party service providers, and have adequate resources (e.g., staff and technology).*

1. Determine whether the institution's security operations activities include the following:
 - a. Security software and device management (e.g., maintaining the signatures on signature-based devices and firewall rules).
 - b. Forensics (e.g., analysis of potentially compromised systems).
 - c. Vulnerability identification (e.g., operation or supervision of vulnerability scans, self-assessments, penetration tests, and analysis of audit results).
 - d. Vulnerability cataloging and remediation tracking.
 - e. Physical security management (e.g., CCTV, guards, and badge systems).
 - f. Law enforcement interface (e.g., data retention and lawful intercepts).
 - g. Third-party integration (e.g., managed security services and incident detection services).
 - h. Monitoring of network, host, and application activity.
 - i. Threat identification and assessment.
 - j. Incident detection and management.
 - k. Enforcement of access controls.
2. Determine whether management establishes defined processes and appropriate governance to facilitate the performance of security operations. Determine whether management coordinates security operations activities with the institution's lines of business and with the institution's third-party service providers.
3. Determine whether management has effective threat identification and assessment processes, including the following:
 - a. Maintaining procedures for obtaining, monitoring, assessing, and responding to evolving threat and vulnerability information.

- b. Identifying and assessing threats (e.g., threat information is often ad hoc, although some providers present threat information within a defined framework that readily lends itself to analytical operations).
 - c. Using tools to assist in the analysis of vulnerabilities (e.g., design of system, operation of the system, security procedures, business line controls, and implementation of the system and controls).
 - d. Using threat knowledge to drive risk assessment and response.
 - e. Designing policies to allow immediate and consequential threats to be dealt with expeditiously.
 - f. Developing appropriate processes to evaluate and respond to vulnerability information from external groups or individuals.
4. Determine whether management has effective threat monitoring processes, including the following:
- a. Defining threat monitoring policies that provide for both continual and ad hoc monitoring of communications and systems, effective incident detection and response, and the use of monitoring reports in subsequent legal proceedings.
 - b. Establishing responsibility and accountability for security personnel and system administrators for monitoring.
 - c. Appropriately reviewing and providing approval of the monitoring tools used.
 - d. Monitoring of indicators, including vulnerabilities, attacks, compromised systems, and suspicious users.
 - e. Monitoring both incoming and outgoing network traffic to identify malicious activity and data exfiltration.
 - f. Establishing and documenting a process to independently monitor administrators and other users with higher privileges.
5. Determine whether management has effective incident identification and assessment processes to do the following:
- a. Identify indicators of compromise.
 - b. Analyze the event associated with the indicators.
 - c. Classify the event.
 - d. Enable the use of response teams and responses depending on the type of event.
 - e. Escalate the event consistent with the classification.
 - f. Report internally and externally as appropriate.
 - g. Identify personnel empowered to declare an incident.
 - h. Develop procedures to test the incident escalation, response, and reporting processes.
6. Determine whether management has effective incident response processes, including the following:
- a. Protocols defined in the incident response policy to declare and respond to an incident once identified.

- b. Procedures to minimize damage through the containment of the incident, restoration of systems, preservation of data and evidence, and notification, as appropriate, to customers and others as needed.
- c. Appropriate balance of adequate people and technologies in the response.
- d. A plan that is comprehensive, coordinated, integrated, and periodically tested with appropriate internal and external parties.
- e. Policies and procedures to guide the response, assigning responsibilities to individuals; providing appropriate training; formalizing information flows; and selecting, installing, and understanding the tools used in the response effort.
- f. Thresholds for reporting significant security incidents and processes to notify, as appropriate, the institution's regulators of those incidents that may affect the institution or the financial system.
- g. Assignment of responsibilities, training, and testing.
- h. Containment strategies.
- i. Restoration and follow-up strategies.

Objective 9: *Determine whether management has an effective information security program.*

1. Determine whether the information security program is subject to periodic review and whether management provides for continual improvement in the program's effectiveness. Verify whether that review does the following:
 - a. Addresses the program in its current environment.
 - b. Demonstrates that lessons learned from experience, audit findings, and other opportunities for improvement are identified and applied.

Objective 10: *Determine whether assurance activities provide sufficient confidence that the security program is operating as expected and reaching intended goals.*

1. Review whether management ascertains assurance through the following:
 - a. Testing and evaluations through a combination of self-assessments, penetration tests, vulnerability assessments, and audits with appropriate coverage, depth, and independence.
 - b. Alignment of personnel skills and program needs.
 - c. Reporting that is timely, complete, transparent, and relevant to management decisions.
2. Determine whether management considers the following key testing factors when developing and implementing independent tests:
 - a. Scope.
 - b. Personnel.
 - c. Notifications.
 - d. Confidentiality, integrity, and availability of the institution's information.
 - e. Confidentiality of test plans and data.
 - f. Frequency.

- g. Proxy testing.
3. Determine whether management uses the following types of tests and evaluations to determine the effectiveness of the information security program. Verify whether management ensures the following are done:
 - a. Periodic self-assessments performed by the organizational unit being assessed.
 - b. Penetration tests that subject a system to real-world attacks and identify weaknesses.
 - c. Vulnerability assessments that define, identify, and classify the security holes found in the system.
 - d. Audits performed by independent internal departments or third parties.
 4. Determine whether management uses independent organizations to test aspects of its information security programs.
 5. Determine whether management uses reporting of the results of self-assessments, penetration tests, vulnerability assessments, and audits to support management decision making.
 6. Determine whether the annual information security report is timely and contains adequate information.

Objective 11: Discuss corrective action and communicate findings.

1. Review preliminary conclusions with the examiner-in-charge regarding the following:
 - a. Violations of laws or regulations.
 - b. Significant issues warranting inclusion as matters requiring attention or recommendations in the report of examination.
 - c. The proposed Uniform Rating System for Information Technology management component rating and the potential impact of the conclusion on the composite or other component IT ratings.
 - d. Potential impact of conclusions on the institution's risk assessment.
2. Discuss findings with management and obtain proposed corrective action for significant deficiencies.
3. Document conclusions in a memo to the examiner-in-charge that provides report-ready comments for all relevant sections of the report of examination and guidance to future examiners.
4. Organize work papers to ensure clear support for significant findings by examination objective.

Appendix B: Glossary

Acceptable use policy: A document that establishes an agreement between users and the enterprise and defines for all parties the ranges of use that are approved before users can gain access to a network or the Internet.

Access: The ability to physically or logically enter or make use of an IT system or area (secured or unsecured). The process of interacting with a system.

Administrator privileges: Computer system access to resources that are unavailable to most users. Administrator privileges permit execution of actions that would otherwise be restricted.

Air-gapped environment: Security measure that isolates a secure network from unsecure networks physically, electrically, and electromagnetically.

Anomalous activity: Activity that deviates from normal. The result of the process of comparing definitions of what activity is considered normal against observed events to identify significant deviations.

Antivirus/anti-malware software: A program that monitors a computer or network to identify all types of malware and prevent or contain malware incidents.

Asset: In computer security, a major application, a general-support system, a high-impact program, a physical plant, a mission-critical system, personnel, equipment, or a logically related group of systems.

Attack signature: A specific sequence of events indicative of an unauthorized access attempt.

Authentication: The process of verifying the identity of an individual user, machine, software component, or any other entity.

Availability: Whether or how often a system is available for use by its intended users. Because downtime is usually costly, availability is an integral component of security.

Baseline configuration: A set of specifications for a system, or configuration item within a system, that has been formally reviewed and agreed on at a given point in time and that can be changed only through change control procedures. The baseline configuration is used as a basis for future builds, releases, or changes.

Black holing: A method typically used by ISPs to stop a distributed denial-of-service (DDoS) attack on one of its customers. This approach to blocking DDoS attacks makes the site in question completely inaccessible to all traffic, both malicious attack traffic and legitimate user traffic.

Border router: A device located at the organization's boundary to an external network.

Change management: The broad processes for managing organizational change. Change management encompasses planning, oversight or governance, project management, testing, and implementation.

Checksum: A mathematical value that is assigned to a file and used to “test” the file at a later date to verify that the data contained in the file has not been maliciously or erroneously changed.

Classification: Categorization (e.g., “confidential,” “sensitive,” or “public”) of the information processed by the service provider on behalf of the receiver company.

Cloud computing: Generally a migration from owned resources to shared resources in which client users receive IT services on demand from third-party service providers via the Internet “cloud.” In cloud environments, a client or customer relocates its resources—such as data, applications, and services—to computing facilities outside the corporate firewall, which the end user then accesses via the Internet.

Cloud storage: A model of data storage in which the digital data is stored in logical pools, the physical storage spans multiple servers (and often locations), and the physical environment is typically owned and managed by a hosting company.

Compensating control: A management, operational, and/or technical control (e.g., safeguard or countermeasure) employed by an organization in lieu of a recommended security control in the low, moderate, or high baselines that provides equivalent or comparable protection for an information system.

Computer security: Technological and managerial procedures applied to computer systems to ensure the availability, integrity, and confidentiality of information managed by the computer system.

Confidentiality: Assuring information will be kept secret, with access limited to appropriate persons.

Configuration management: The management of security features and assurances through control of changes made to a system’s hardware, software, firmware, documentation, testing, test fixtures, and test documentation throughout the development and operational life of the system.

Consumer information: For purposes of the Information Security Standards, “consumer information” means any record about an individual, whether in paper, electronic, or other form, that is a consumer report or is derived from a consumer report that is maintained by or on behalf of a financial institution for a business purpose, such as information that an institution obtains about a loan applicant or a prospective employee from a consumer report.

Control: The means of managing risk, including policies, procedures, guidelines, practices, or organizational structures, which can be of an administrative, technical, management, or legal nature.

Control requirements: Process used to document and/or track internal processes to determine that those established procedures and/or physical security policies are being followed.

Control self-assessment: A technique used to internally assess the effectiveness of risk management and control processes.

Corrective control: A mitigating technique designed to lessen the impact to the institution when adverse events occur.

Crisis management: The process of managing an institution's operations in response to an emergency or event that threatens business continuity. An institution's ability to communicate with employees, customers, and the media, using various communications devices and methods, is a key component of crisis management.

Critical system (infrastructure): The systems and assets, whether physical or virtual, that are so vital that the incapacity or destruction of them may have a debilitating impact.

Customer: For purposes of the Information Security Standards, "customer" means a consumer with whom a financial institution has a continuing relationship under which the institution provides one or more financial products or services to the consumer that are to be used primarily for personal, family, or household purposes. In the case of a credit union, a customer relationship will exist between a credit union and certain consumers that are not the credit union's members.

Customer information: A term used in the Information Security Standards to mean any record containing non-public personal information about a customer, whether in paper, electronic, or other form, that is maintained by or on behalf of a financial institution.

Customer information systems: For purposes of the Information Security Standards, "customer information systems" means any methods used to access, collect, store, use, transmit, protect, or dispose of customer information.

Cyber attack: An attempt to damage, disrupt, or gain unauthorized access to a computer, computer system, or electronic communications network. An attack, via cyberspace, targeting an institution for the purpose of disrupting, disabling, destroying, or maliciously controlling a computing environment/infrastructure; destroying the integrity of the data; or stealing controlled information.

Cyber event: A cybersecurity change or occurrence that may have an impact on organizational operations (including mission, capabilities, or reputation).

Cyber incident: Actions taken through the use of computer networks that result in an actual or potentially adverse effect on an information system or the information residing therein.

Cyber resilience: The ability of a system or domain to withstand cyber attacks or failures and, in such events, to reestablish itself quickly.